

Workspace decisions and immediate actions

Ozofi Nexus (EMS) · Phase 0 design, owner decisions final · Source:

docs/audit/WORKSPACE_FOUNDATION_PHASE0.md · Code state: branch fix/HF-10-prevent-role-escalation, commit 0b9ce1a (local, nothing pushed)

1. Architecture (approved)

Permissions → Module Registry → Widget Registry → Organization default → Department default → User workspace → Rendered UI. Permissions decide what a person **can** access; the workspace decides what they **see**. A role is only a bag of permissions and never selects a screen.

Registries (modules, widgets, quick actions) live in **code** and change only through reviewed releases; layouts, templates, assignments and policies live in the **database**. The server returns a permission-filtered catalogue (/me/workspace-catalog); the client never computes access. Stored layouts contain only ids and presentation flags: module_id, widget_id, size, order, hidden, favorite, pinned. They never contain routes, permissions, components, roles or labels. React routes stay **code-defined** in a static route map; the registry controls visibility only.

2. Final decisions

#	Decision
D-1	Department default above role default. Order: User workspace → Department → Role → Organization → Platform default (→ permanent modules only). A Finance Manager starts from Finance.
D-2	Widget size kept , presentation only: size is s, m or l. Workspace data can never carry permissions, routes or components.
D-3	Department health gate. Counts of employees with NULL department_id, invalid department_id, and department text that does not match the department name. Added to the OW-4 export (section 10). Department defaults are enabled per tenant only when the report is clean enough.
D-4	Minimal /help page ships with Foundation (permanent module): Contact HR, Contact Admin, Knowledge Base, FAQ, Support e-mail. It does not delay launch.
D-5	Merge priority: Permanent → Locked workspace → User overrides → Activated templates → Defaults. The user's own hidden state beats a template, never a permanent module or a locked workspace.
D-6	New permissions, separate from settings:manage: workspaces:create, workspaces:manage, workspaces:share, workspaces:manage_templates. Seeded in Foundation; never inferred from role names.
D-7	Saved Views added under modules (e.g. Employees → New Joiners, Probation, Expiring Documents). A view stores only module id plus a validated filter; it can narrow, never widen, access. Reserved in the schema now, built in Phase 3.
D-8	Hard gate: widget feed separation. /reports/dashboard (and the manager and employee payloads) must be split into permission-safe feeds so that reports:view stops carrying payroll aggregates, audit rows and finance metrics.
D-9	Registry ids are immutable forever. Never renamed, never reused; a rename keeps the old id as an alias so saved layouts keep working. CI compares against the last release.
D-10	Workspace export / import / clone (Phase 2 or 3): JSON of registry ids and presentation flags only; validated on import; gated by workspaces:share / manage_templates.

Permanent modules: Dashboard, My Profile, Notifications, Help & Support. **Templates** are job-to-be-done compositions (People Operations, Payroll Operations, Recruitment, Attendance Control, Executive View, Finance View, Project Delivery, My Day); a user can activate several. Defaults apply only to someone who has activated nothing.

3. Phasing

Phase	Scope
1 – Foundation	Module and widget registries, server-filtered catalogue, resolver, personal layout, dynamic permission-filtered sidebar and generated routes, hide / show / reorder / favorites / pin, personal widget visibility, permanent modules, default chain. Per-tenant flag, shadow mode first.
2 – Builder	Multiple templates per user, department templates and assignments, workspace sharing, locked company workspaces, tenant policy switches, drag and drop.
3	Team workspaces, saved operational views, tenant custom links (permission-bound), template library.

4. Gates before any Workspace implementation (all required)

Gate	State
HF-9A – remove the dashboard_type and super_admin-by-name bypasses	BLOCKED on the OW-4 production export
HF-9B – replace role-name guards with permission guards	After HF-9A
Canonical permission catalogue (one vocabulary)	Needs OW-4 to choose names that exist in production
Own / team scope permissions (*:view_own, *:view_team)	Not started; required to retire the hard-coded core-modules list
Widget feed separation (D-8)	Not started; inventory is in Phase 0 section 2.2
Department health acceptable (D-3)	Report is in the OW-4 export
Parity report clean (old sidebar vs registry, per role)	Needs OW-4 data

5. Immediate actions

#	Action	Owner
1	Run docs/audit/OW4_PERMISSION_EXPORT.sql against production (read-only, no personal data) and send ow4_export.txt.	Owner
2	HF-9A: analyse the export (who depends on the bypass, which permissions each legacy role needs), grant those permissions first, then remove the bypass.	Engineering, after 1
3	HF-9B: permission guards on settings, organization, employees, documents, performance and governance.	Engineering, after 2
4	Design the canonical permission catalogue and the own/team scope permissions from the matrix plus the export.	Engineering, after 1
5	D-8 widget feed decomposition: design done (docs/audit/WIDGET_FEED_DECOMPOSITION.md). Optional small hardening item HF-12A: field-filter compensation, demographics and audit data out of /reports/{admin,dashboard,summary,departments}. Needs owner go.	Owner decision, then engineering
6	Behaviour-free pre-step: rename the client hook useWorkspace to useOrganization so that “workspace” means only the saved layout.	Engineering (safe any time)

Known client defects found during the inventory (not fixed): the policies widget calls /settings/config, so ordinary employees receive 403; the organization calendar widget calls /reports/holidays, which does not exist.

Explicitly not happening yet: no Workspace code, tables, routes, permissions or flags; no change to authorization behaviour; nothing pushed, merged or deployed.